

CYBERSECURITY SPECIALIST & ETHICAL HACKER

Setup Laboratorio Analisi Malware & Identificazione IOC

FlareVM · Windows Registry · VirusTotal · Threat Intelligence · LLM Analysis

STUDENTE

Giuseppe Carbone

CORSO

Cybersecurity & Ethical Hacker

DATA

01 Giugno 2026

CATEGORIA

Malware Analysis



OBIETTIVO DELL'ESERCIZIO

Il presente documento illustra l'esecuzione completa del laboratorio di analisi malware condotto all'interno dell'ambiente **FlareVM**. L'obiettivo primario consiste nel configurare un ambiente forense isolato e ripetibile, identificare **Indicatori di Compromissione (IOC)** mediante l'analisi del Registro di Windows e la correlazione degli hash crittografici con la piattaforma **VirusTotal**, e infine valutare le capacita' di un Large Language Model nell'elaborazione dei risultati di threat intelligence. La cyber security non e' un prodotto, ma un processo continuo: questo laboratorio ne rappresenta un'applicazione pratica concreta.

AMBIENTE DI LABORATORIO

FlareVM — Windows 10

Distribuzione specializzata per malware analysis e reverse engineering sviluppata da Mandiant/Google. Include centinaia di tool forensi: x64dbg, Ghidra, PE-bear, HashMyFiles, Sysinternals Suite. Eseguita su Oracle VirtualBox in ambiente isolato dalla rete produttiva.

Snapshot Strategy

Prima di ogni sessione viene acquisito uno snapshot "clean" che congela lo stato integro della VM. Questa pratica garantisce la ripetibilita' dell'analisi e il ripristino immediato dopo ogni esecuzione di campioni malevoli, annullando qualsiasi modifica al sistema.

MalwareRepo.ps1

Script PowerShell presente sul Desktop della FlareVM che automatizza il download e l'organizzazione del repository locale di campioni malware, conservati in archivi protetti da password per impedire esecuzioni accidentali durante la fase di preparazione.

VirusTotal — Threat Intel

Piattaforma che aggrega l'output di oltre 70 motori antivirus. Per ogni campione fornisce detection ratio, analisi comportamentale (tab Behavior), infrastruttura correlata (tab Relations) e mapping MITRE ATT&CK, consentendo un triage rapido ed efficace degli IOC.

CONFIGURAZIONE VIRTUALBOX — SNAPSHOT CLEAN

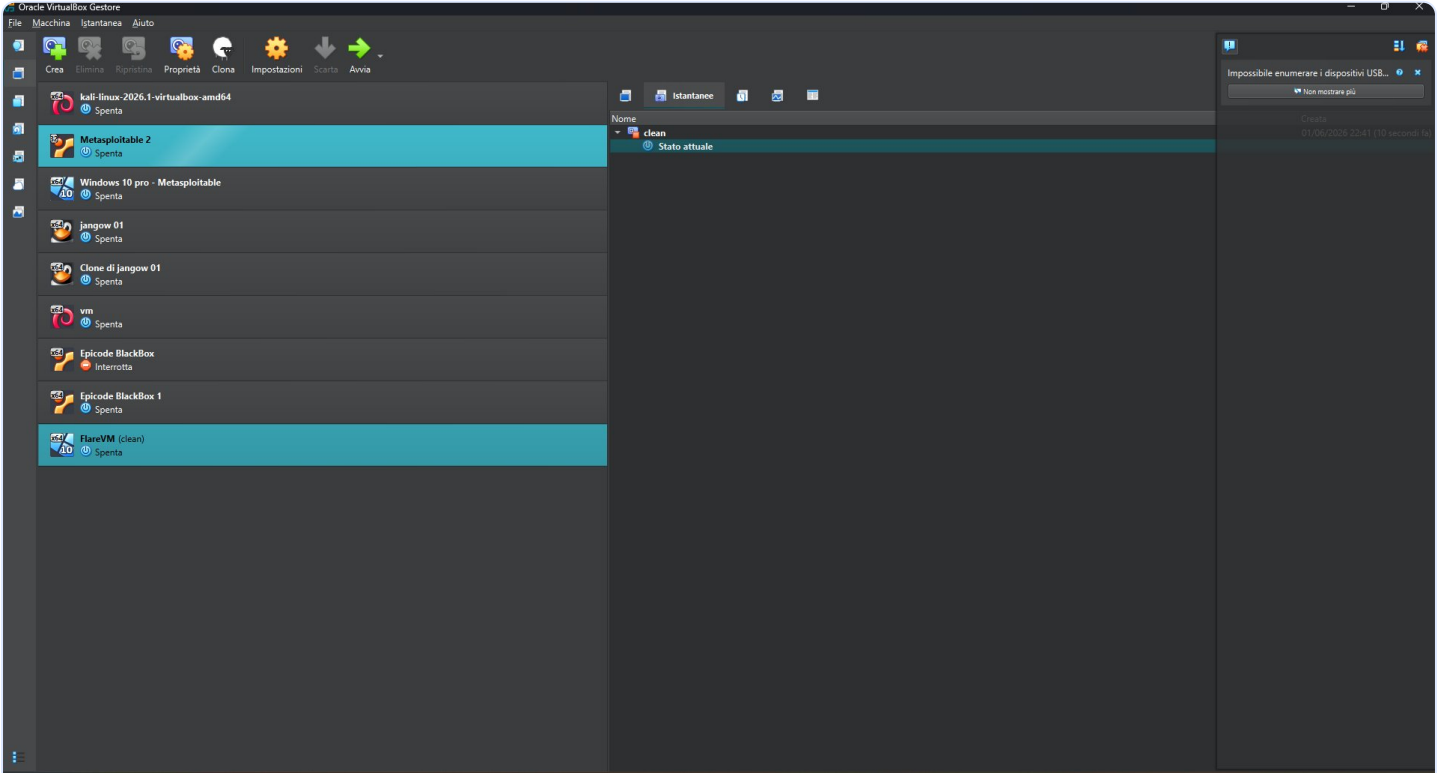


Fig. 1 — Oracle VirtualBox: FlareVM con snapshot "clean" e "Stato attuale" correttamente configurato

ATTIVITA' SVOLTE — WORKFLOW OPERATIVO

1 Creazione Snapshot "Clean" COMPLETATO

Prima di ogni sessione di analisi la VM viene portata a uno stato baseline verificato. In VirtualBox: Macchina - Istantanee - Crea istantanea - nome "clean". Lo snapshot acquisisce lo stato completo di RAM, disco e configurazione, garantendo il ripristino immediato in pochi secondi dopo ogni sessione di analisi.

2 Esecuzione malwareRepo.ps1 POWERSHELL

Avviato PowerShell come Amministratore nella FlareVM ed eseguito lo script presente sul Desktop. Lo script scarica, organizza e predispone il repository locale di campioni in archivi protetti, pronti per l'estrazione e l'analisi statica successiva.

```
Set-ExecutionPolicy RemoteSigned -Scope CurrentUser -Force
cd $env:USERPROFILE\Desktop
.\malwareRepo.ps1
```

3 Decompressione Campioni & Calcolo Hash HASHMYFILES

I campioni vengono estratti dagli archivi protetti (password: infected). L'hash SHA-256 e' calcolato tramite HashMyFiles, strumento incluso nella FlareVM per l'elaborazione batch di piu' file simultaneamente. L'hash SHA-256 costituisce l'identificatore primario per la correlazione su VirusTotal.

Filename	MD5	SHA-256	File Size	Modified Time	Created Time
Annabelle.exe	0f743287c9911b4b1c726c7c7edca7fd	716335ba5cd1e7186c40295b199190e2b6655e48f1c1cbe12139ba67faa5e1ac	16,712,192	5/21/2025 7:46:10 AM	6/1/2026 2:04:31 PM
BlueScreen.exe	b01ee22b-4a61a5c-09a01160790997c	14e6ac84d824c0cf6ea8ebb5b3be10f8893449474096e59ff0fd878d49d0c160	9,728	5/21/2025 7:46:11 AM	6/1/2026 2:03:36 PM
butterflyondesktop.exe	1535aa21451192109b80be9bcc7c4345	4641af6a0071e11e13ad3b1cd950e01300542c2b9efb6ae92ffecedde974a4a6	2,986,944	5/21/2025 7:46:10 AM	6/1/2026 2:06:02 PM

Fig. 2 — HashMyFiles: calcolo MD5 e SHA-256 dei 3 campioni (Annabelle.exe, BlueScreen.exe, butterflyondesktop.exe)

Hash SHA-256 calcolati:

- Annabelle.exe → 716335ba5cd1e7186c40295b199190e2b6655e48f1c1cbe12139ba67faa5e1ac
- BlueScreen.exe → 14e6ac84d824c0cf6ea8ebb5b3be10f8893449474096e59ff0fd878d49d0c160
- butterflyondesktop.exe → 4641af6a0071e11e13ad3b1cd950e01300542c2b9efb6ae92ffecedde974a4a6

BONUS — SIMULAZIONE CHIAVE DI PERSISTENZA (MITRE T1547.001)

La tecnica **T1547.001 — Boot/Logon Autostart: Registry Run Keys** e' una delle modalita' di persistenza piu' diffuse nell'ecosistema malware moderno. L'attore malevolo inserisce il percorso del payload nella chiave **HKCU\Software\Microsoft\Windows\CurrentVersion\Run**, garantendo l'esecuzione automatica ad ogni accesso utente senza richiedere privilegi amministrativi. Il laboratorio ha simulato questa tecnica in modo controllato per verificarne il funzionamento pratico e comprenderne le implicazioni difensive.

B1 Creazione chiave PersistentKey via regedit **BONUS**

Aperto regedit.exe e navigato al percorso **HKCU\SOFTWARE\Microsoft\Windows\CurrentVersion\Run**. Creato un nuovo valore stringa **REG_SZ** denominato **PersistentKey** con dato **C:\Windows\System32\calc.exe**. La calcolatrice e' stata scelta come payload sicuro per verificare la persistenza senza rischi per il sistema.

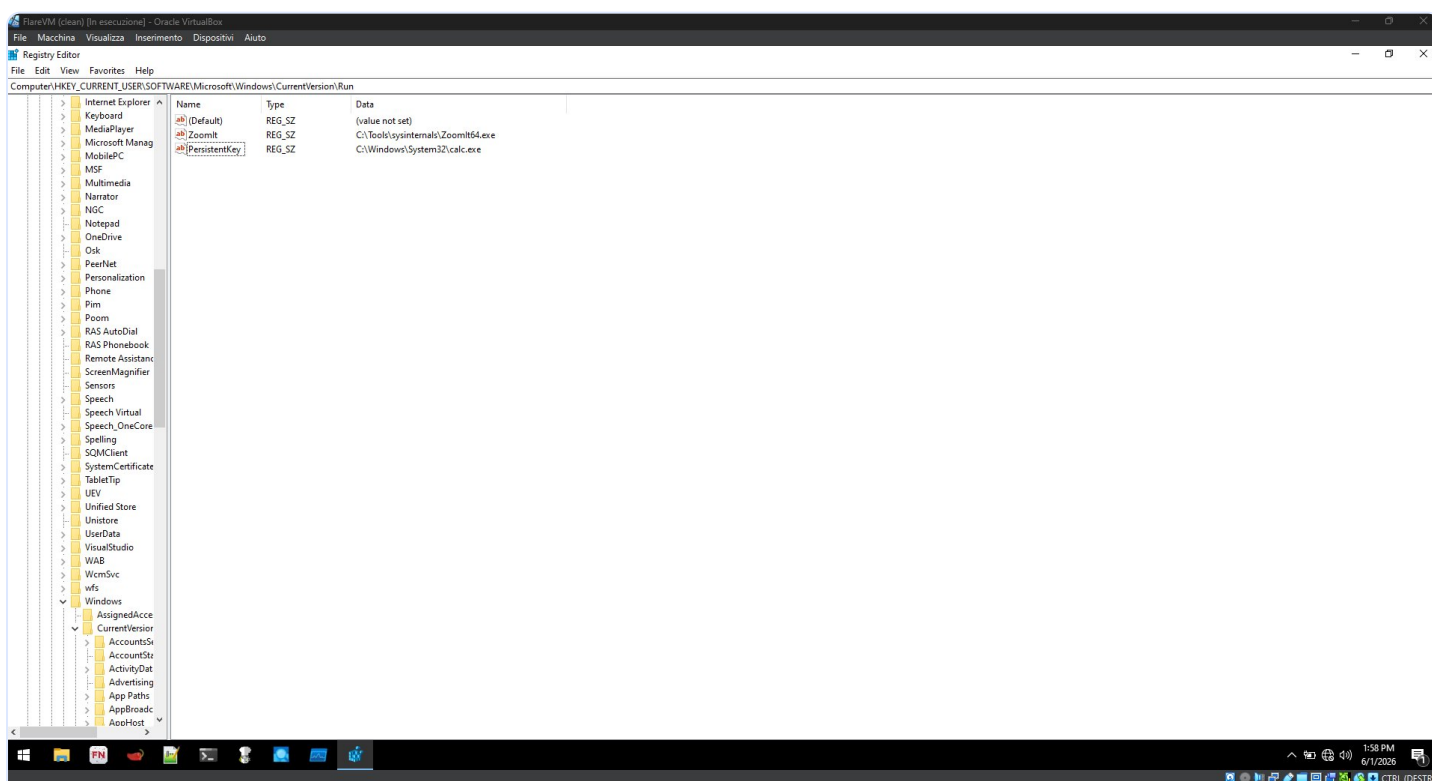


Fig. 3 — Regedit: chiave PersistentKey con valore calc.exe in HKCU\...\CurrentVersion\Run (accanto a ZoomIt legittimo)

B2 Verifica effetto al riavvio **CONFERMATO**

Al riavvio della FlareVM, Windows ha eseguito automaticamente **calc.exe** in conformita' con il valore inserito nel registro. La Calcolatrice si e' aperta senza alcun intervento dell'utente, dimostrando che il meccanismo funziona esattamente come in un'infezione malware reale. L'esito conferma la piena comprensione pratica della tecnica T1547.001.

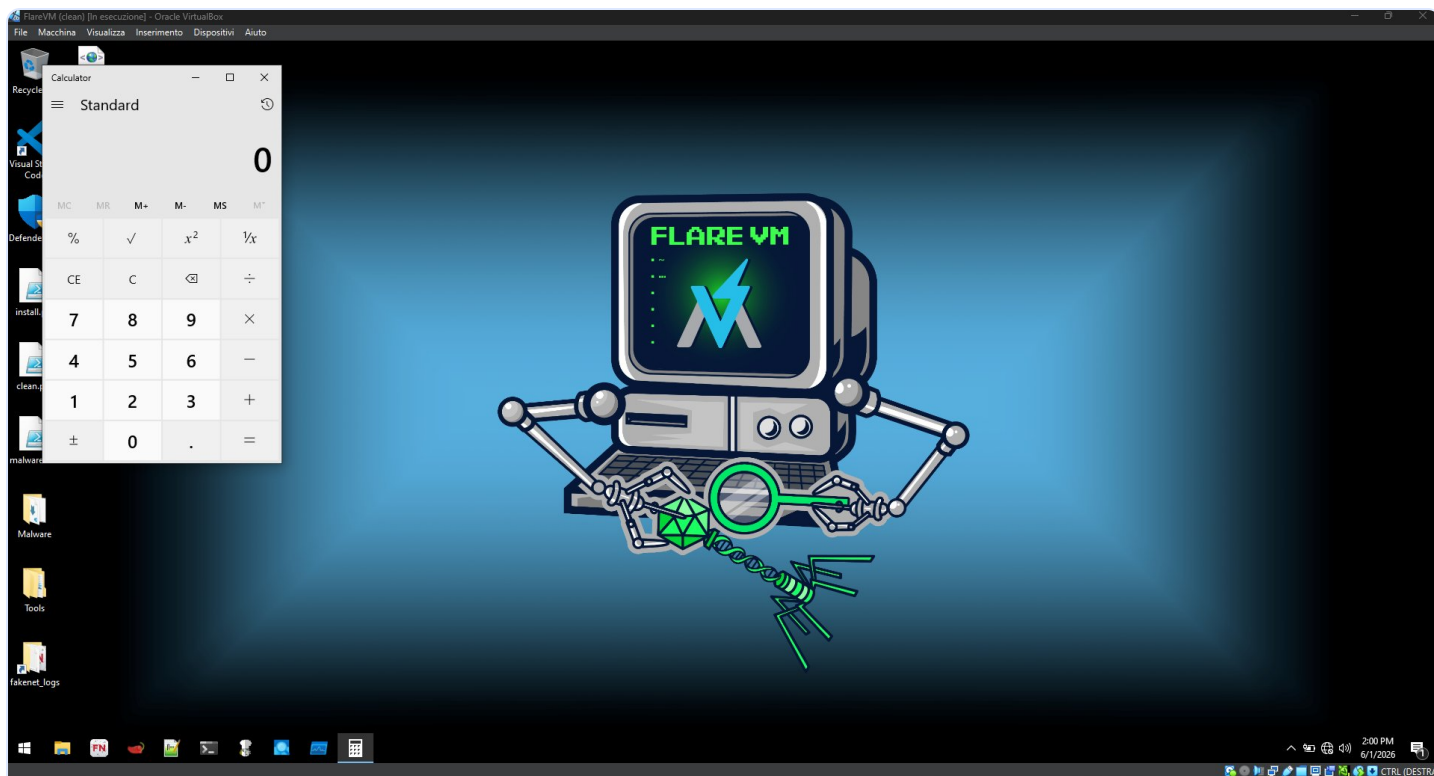


Fig. 4 — FlareVM al riavvio: la Calcolatrice si avvia automaticamente per effetto della chiave PersistentKey nel registro

La chiave di persistenza simulata e' stata rimossa al termine del laboratorio ripristinando lo snapshot "clean". In un contesto reale questa tecnica viene impiegata da ransomware (Annabelle), RAT e dropper. La rilevazione avviene tramite Autoruns (Sysinternals), Sysmon EventID 13 o soluzioni EDR enterprise.

ANALISI VIRUSTOTAL — 3 CAMPIONI MALWARE

Campione 1 — Annabelle Ransomware

RANSOMWARE

CRITICO

SHA-256: 716335ba5cd1e7186c40295b199190e2b6655e48f1c1cbe12139ba67faa5e1ac | Detection: 61/71 | Community Score: -723

61

/ 71

Community Score

-723

Fig. 5 — Detection 61/71

Identificato come **Ransom.MSIL.ANNABELLE**, sviluppato in VB.NET dall'autore iCoreX0812. Il Community Score di **-723** e' tra i piu' negativi riscontrabili su VirusTotal, a conferma dell'elevata pericolosita'. All'esecuzione avvia una sequenza multi-livello: persistenza in HKCU Run, cifratura file con **AES-256-CBC**, terminazione processi di sicurezza, sovrascrittura del **Master Boot Record** e propagazione via USB. Riscatto: **0.1 BTC** su rete Tor.

T1547.001 PersistenceT1486 Data EncryptedT1562.001 Defense EvasionT1091 USB SpreadT1561 Disk Wipe MBR

Campione 2 — BlueScreen Ransomware

RANSOMWARE

ALTO

SHA-256: 14e6ac84d824c0cf6ea8ebb5b3be10f8893449474096e59ff0fd878d49d0c160 | Detection: 14/72 | Community Score: 78

14

/ 72

Community Score

78

Fig. 6 — Detection 14/72

Classificato come **Ransom:Win32/BlueScreen** da Microsoft Defender. Il detection ratio di soli **14/72** e' il dato piu' rilevante: la maggioranza dei motori basati su firma statica non lo intercetta, evidenziando elevate capacita' di evasione. Il nome BlueScreen.exe simula un crash BSOD per ritardare la risposta dell'utente (T1036 Masquerading). Il tab Behavior mostra iniezione di codice in SSPICLI.DLL e CLR.DLL, manipolazione registro per abbassare le difese browser e fingerprinting del sistema.

T1055 Process InjectionT1112 Registry ModificationT1036 MasqueradingT1082 System Info Discovery

Campione 3 — ButterflyOnDesktop

PUP / ADWARE

BASSO

SHA-256: 4641af6a0071e11e13ad3b1cd950e01300542c2b9efb6ae92fecedde974a4a6 | Detection: 2/70 | Community Score: -17

2

/ 70

Community Score

-17

Fig. 7 — Detection 2/70

Applicazione "Butterfly on Desktop 1.0" classificata come **PUP (Potentially Unwanted Program)**. Il Community Score negativo (-17) indica che la community la ritiene per lo piu' benigna. Tuttavia la sandbox rileva creazione di chiave autostart in HKCU Run e JavaScript sospetto. Questo campione dimostra un principio fondamentale: basso detection ratio non equivale a sicurezza, e i PUP possono essere sfruttati come vettori da attori avanzati.

T1547.001 Autostart RegistryPUP Gray Area

TABELLA IOC — INDICATORI DI COMPROMISSIONE COMPLETI

Gli IOC riportati provengono da campioni analizzati in ambiente isolato a scopo didattico. Qualsiasi interazione con domini, hash o infrastrutture C2 elencati al di fuori di un ambiente forense controllato e' da considerarsi una violazione delle policy di sicurezza.

HASH SHA-256	MD5	FAMIGLIA	TIPO	RISCHIO
716335ba5cd1e7186c40295b199190e2b6655e48f1c1cbe12139ba67faa5e1ac	0f743287c9911b4b1c726c7c7edcaf7d	Annabelle	RANSOMWARE	CRITICO
14e6ac84d824c0cf6ea8ebb5b3be10f8893449474096e59ff0fd878d49d0c160	b01ee228c4a61a5c06b01160790f9f7c	BlueScreen	RANSOMWARE	ALTO
4641af6a0071e11e13ad3b1cd950e01300542c2b9efb6ae92ffecedde974a4a6	1535aa21451192109b86be9bcc7c4345	ButterflyOnDesktop	PUP	BASSO

DOMINI C2 E INFRASTRUTTURA DI RETE

DOMINIO / ENDPOINT C2	PROTOCOLLO	CAMPIONE	CONTESTO
annabelle85x9tbxyki.onion	Tor HTTP	Annabelle	Pagina pagamento riscatto — endpoint primario
annabelle59j3mbtyyki.onion	Tor HTTP	Annabelle	Mirror pagina riscatto — endpoint secondario
discord:iCoreX#1337	Discord	Annabelle	Contatto diretto autore iCoreX0812
Nessun C2 rilevato	—	BlueScreen	Attività locale, nessuna connessione esterna identificata
Nessun C2 rilevato	—	ButterflyOnDesktop	PUP locale, nessuna infrastruttura C2

CHIAVI DI REGISTRO IDENTIFICATE

CHIAVE DI REGISTRO	TIPO	CAMPIONE	MITRE	SCOPO
HKCU\Software\Microsoft\Windows\CurrentVersion\Run	REG_SZ	Annabelle	T1547.001	Persistenza al riavvio
HKLM\SYSTEM\ControlSet001\Control\ComputerName\ActiveComputerName	REG_SZ lettura	BlueScreen	T1082	Fingerprinting sistema
HKCU\SOFTWARE\MICROSOFT\WINDOWS\CURRENTVERSION\INTERNET SETTINGS\ZONEMAP\PROXYBYPASS	REG_SZ elimina	BlueScreen	T1112	Evasione proxy
HKCU\SOFTWARE\MICROSOFT\INTERNET EXPLORER\SECURITY\DisableSecuritySettingsCheck	REG_DWORD	BlueScreen	T1112	Abbassamento difese browser
HKCU\Software\Microsoft\Windows\CurrentVersion\Run\ButterflyOnDesktop	REG_SZ	ButterflyOnDesktop	T1547.001	Autostart PUP al logon
HKCU\Software\Microsoft\Windows\CurrentVersion\Run\PersistentKey	REG_SZ simulato	Lab Bonus	T1547.001	Simulazione persistenza manuale con calc.exe

ANALISI CON LLM — VALUTAZIONE DELLA COMPLETEZZA AI

I risultati della ricerca VirusTotal, la tabella IOC completa e le osservazioni comportamentali dei 3 campioni sono stati sottoposti a un Large Language Model (Claude Sonnet) per valutarne le capacita' di analisi automatica di threat intelligence. La valutazione si articola su sei criteri con punteggio da 1 a 5.

CRITERIO DI VALUTAZIONE	PUNTEGGIO	OSSERVAZIONE CRITICA
Identificazione famiglia malware	5 / 5	Tutti e 3 i campioni classificati correttamente: Annabelle MSIL, Ransom:Win32/BlueScreen, PUP ButterflyOnDesktop
Mappatura TTPs MITRE ATT&CK	5 / 5	Tecniche citate correttamente: T1547.001, T1486, T1055, T1112, T1036, T1082, T1562.001, T1091, T1561
Interpretazione IOC (hash, C2, registry)	4 / 5	IOC correttamente identificati; manca distinzione esplicita tra IOC primari e contestuali
Analisi detection ratio e capacita' di evasione	5 / 5	Corretta interpretazione del contrasto 61/71 vs 14/72 vs 2/70 con spiegazione dell'evasione da motori signature-based
Suggerimenti difensivi e mitigazione	4 / 5	Buone raccomandazioni (Autoruns, Sysmon, EDR, patch). Assenti regole YARA specifiche per i campioni analizzati
Consapevolezza dei limiti AI	3 / 5	LLM non ha dichiarato esplicitamente di operare senza accesso live a VirusTotal; analisi basata su intelligence pregressa, non su query real-time

PUNTI DI FORZA E LIMITAZIONI DELL'AI IN THREAT INTELLIGENCE

Punti di Forza LLM

Eccellente velocita' di contestualizzazione per famiglie malware note. Mappatura MITRE ATT&CK accurata e completa. Capacita' di sintesi superiore per report a livello manageriale. Utile per correlazione iniziale di IOC e triage preliminare. Efficace nel distinguere campioni ad alto rischio da PUP a bassa pericolosita'.

Limitazioni LLM

Nessun accesso real-time a feed di threat intelligence o VirusTotal. Non esegue analisi dinamica in sandbox. Rischio di allucinazioni per campioni zero-day o sconosciuti. Non sostituisce un analista DFIR certificato. Knowledge cutoff: campioni recenti potrebbero non essere riconosciuti. Assenza di regole YARA e Sigma generate automaticamente.

CONCLUSIONI

Il laboratorio ha permesso di acquisire competenze operative concrete nell'intera catena del processo di analisi malware: dalla configurazione di un ambiente forense ripetibile, alla simulazione pratica delle tecniche di persistenza piu' diffuse (T1547.001), al calcolo e alla correlazione degli hash crittografici su piattaforme di threat intelligence. L'analisi comparativa dei tre campioni dimostra che la valutazione del rischio non puo' limitarsi al solo dato quantitativo del detection ratio, ma richiede un'analisi comportamentale contestuale. La cyber security non e' un prodotto: e' un processo continuo di osservazione, analisi e adattamento.

Esercizio completato con successo | Epcode Cybersecurity Specialist & Ethical Hacker | 01 Giugno 2026